ONE-PAGE BRIEF

# Post-quantum cryptography review: sigstore-js @ 769a53d87132

Client: Sigstore project — public repository (passive review) · Source: github.com/sigstore/sigstore-js, commit 769a53d87132 · Reviewed: 2026-11-04 19:28 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY
**Level 0 of 4**
no post-quantum cryptography

FINDINGS
**1** Critical **9** High **15** Medium
**2** Low **2** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)
Signatures: 10 + 5 − 8 = 7 → **too late**

**Next step:** Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

## WHAT MATTERS MOST

| | |
|---|---|
| Critical<br>QSI-2026-12855 | **proxy-addr 2.0.7 is affected by GHSA-jqcg-44mw-7w3h (CVE-2026-90711)**<br>What to do: Upgrade to a fixed version (2.0.8). |
| High<br>QSI-2026-12833 | **Private key material present in packages/cli/src/signer.ts**<br>What to do: Treat the key as compromised: rotate it, revoke associated certificates, remove it from version history and store keys in a secrets… |
| High<br>QSI-2026-12831 | **Certificate has expired ((empty))**<br>What to do: Renew the certificate and automate renewal (e.g. ACME) with expiry monitoring. |
| High<br>QSI-2026-12837 | **brace-expansion 5.0.9 is affected by GHSA-6j4f-fj2g-mc7p (CVE-2026-102276)**<br>What to do: Upgrade to a fixed version (1.1.19, 2.1.5, 3.0.7, 5.0.10). |

23 more in the full report.

## WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

| Role | Algorithms | What to do |
|---|---|---|
| Medium role not determined | ECDSA | Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205)… |

## KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 22; each needs checking against the code.

Static review of source code and manifests; files analysed: 180. No requests were sent to the owner's systems.

Full report, content SHA-256: `f1e3600f0297419c9c33b55b3d015472213d69f82d285a251aaa4b2fa5f13731`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.